

Exploiting LLM APIs with Excessive Agency

Author: Moe Htet Ar Kar (Phoe Cho)

1. Vulnerability Concept & Mechanics

Excessive agency occurs when an LLM is connected to powerful backend APIs with overly broad permissions, insufficient parameter validation, or inadequate isolation. Instead of restricting the LLM to narrow, business-specific operations, the application may expose powerful debugging, administrative, or data-access functionality through the model's tool-calling interface.

2. Attack Vector & Exploitation Methodology

API Discovery

Identify the backend APIs and tool functions accessible to the AI agent, including their expected arguments and permissions.

Parameter Manipulation

Identify insufficiently validated parameters, particularly parameters capable of accepting arbitrary values or high-impact operations.

Request Chaining

Analyze whether outputs from sensitive API calls can be passed into subsequent actions, potentially enabling unauthorized data access, privilege escalation, or other attack chains.

3. Validation & Impact

- **Impact:** Unauthorized database access, vertical privilege escalation, sensitive-data exposure, and potential lateral movement across internal services.
- **Validation:** Verify whether an unauthorized user can cause the AI agent to invoke restricted backend functionality or access data beyond the user's intended privileges.

4. Remediation & Hardening

- Restrict API access to dedicated service accounts with tightly scoped permissions.
- Implement strict parameter sanitization, schema validation, and type checking on all backend endpoints accessible to AI agents.
- Avoid exposing raw database execution or administrative debugging APIs to LLM orchestration layers.
- Apply authorization checks independently at the API layer rather than relying solely on the LLM to enforce permissions.